

SPLUNK Part 2

New Search

1 index=main

✓ 18,744 events (before 5/24/26 1:08:50.000 PM) No Event Sampling

Events (18,744) Patterns Statistics Visualization

Format Timeline Zoom Out Zoom to Selection Deselect

List Format 20 Per Page

< Prev 1 2 3 4 5 6

< Hide Fields All Fields

SELECTED FIELDS

- # host 1
- # source 2
- # sourcetype 2

INTERESTING FIELDS

- # client_ip 100+
- # date_hour 24
- # date_minute 60
- # date_month 1
- # date_second 60
- # date_week 7
- # date_year 1

Events

Time	Event
10/20/25 11:52:57.198 PM	2025-10-20T23:52:57.198.51.100.55,GET,/upload.php,200,1025,https://tbfc.thm/,Ruby/2.7.0 (Webshell Runner),tbfc.thm host = lab source = access.csv sourcetype = web_traffic
10/20/25 11:49:36.192 PM	2025-10-20T23:49:36.192.168.182.61,GET,/static/app.css,404,4072,https://tbfc.thm/,"Mozilla/5.0 (Macintosh; Intel Mac OS 5.1.15 (KHTML, like Gecko) Version/17.4 Safari/605.1.15",tbfc.thm host = lab source = access.csv sourcetype = web_traffic
10/20/25 11:47:36.192 PM	2025-10-20T23:47:36.192.168.59.91,POST,/index.html,304,3093,https://tbfc.thm/,"Mozilla/5.0 (Windows NT 10.0; Win64; x64; L, like Gecko) Chrome/129.0.0.0 Safari/537.36",tbfc.thm host = lab source = access.csv sourcetype = web_traffic
10/20/25 11:46:43.000 PM	{ [-] action: DROPPED bytes_transferred: 441 dest_ip: 192.168.219.164

Starting a tryhackme lab

< Hide Fields All Fields

date_year 1

date_zone 1

domain 1

index 1

linecount 1

method 2

path 23

punct 89

referer 1

size_bytes 100+

splunk_server 1

status 7

time 100+

timeendpos 2

timestartpos 2

user_agent 11

10 more fields

+ Extract New Fields

user_agent

11 Values, 91.613% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Top 10 Values

Value	Count	%
Mozilla/5.0 (iPhone; CPU iPhone OS 17_5 like Mac OS X) AppleWebKit/605.1.15 (KHTML, like Gecko) Mobile/15E148 Safari/604.1	3,160	18.402%
Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/129.0.0.0 Safari/537.36	3,075	17.907%
Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/17.4 Safari/605.1.15	3,061	17.826%
Wget/1.21.4	1,240	7.221%
zgrab/0.x	1,238	7.209%
curl/7.88.1	1,220	7.104%
Go-http-client/1.1	1,201	6.994%
Havij/1.17 (Automated SQL Injection)	993	5.783%
sqlmap/1.7.9#stable (http://sqlmap.org)	967	5.631%
python-requests/2.28.1	510	2.97%

10/20/25 11:29:52.192 PM 2025-10-20T23:23:52.192.168.21.225,GET,/blog,404,4111,,,"Mozilla/5.0 (Macintosh; Intel Mac OS X version/17.4 Safari/605.1.15",tbfc.thm
host = lab source = access.csv sourcetype = web_traffic

Typical Software used by users

But this one is very sus

Finding suspicious software used by user in user_agent field.

New Search

1 index=main user_agent="Havij/1.17 (Automated SQL Injection)"

✓ 993 events (before 5/24/26 1:42:04.000 PM) No Event Sampling ▼

Events (993) Patterns Statistics Visualization

Format Timeline ▼ — Zoom Out + Zoom to Selection × Deselect

List ▼ Format 20 Per Page ▼

< Hide Fields :≡ All Fields

SELECTED FIELDS

- a host 1
- a source 1
- a sourcetype 1

INTERESTING FIELDS

- a client_ip 1
- # date_hour 24
- # date_mday 20
- # date_minute 60
- a date_month 1
- # date_second 60
- a date_wday 7
- # date_year 1

client_ip

1 Value, 100% of events

Selected Yes No

Reports

- Top values
- Top values by time
- Rare values
- Events with this field

Values	Count	%
198.51.100.55	993	100%

All of those non-standard software is used by the same ip

< Hide Fields :≡ All Fields

SELECTED FIELDS

- a host 1
- a source 2
- a sourcetype 2

INTERESTING FIELDS

- a client_ip 100+
- # date_hour 24
- # date_mday 20
- # date_minute 60
- a date_month 1
- # date_second 60
- a date_wday 7
- # date_year 1
- a date_zone 1
- a domain 1
- a index 1
- # linecount 1
- a method 2
- a path 23
- a punct 89
- a referer 1
- # size bytes 100+

client_ip

>100 Values, 91.613% of events

Selected Yes No

Reports

- Top values
- Top values by time
- Rare values
- Events with this field

Top 10 Values

Values	Count	%
198.51.100.55	7,876	45.865%
192.168.121.33	3	0.017%
192.168.185.181	3	0.017%
192.168.217.80	3	0.017%
192.168.239.127	3	0.017%
192.168.244.228	3	0.017%
192.168.3.118	3	0.017%
192.168.31.99	3	0.017%
192.168.81.70	3	0.017%
192.168.12.166	2	0.012%

src_port: 53019
timestamp: 2025-10-20T23:46:43

Show as raw text

7876 logs
for 1 ip is
very sus

Checking client_ip in fields to check if something suspicious logs can be found

```

r host 1
r source 2
r sourcetype 2

INTERESTING FIELDS
r client_ip 100+
# date_hour 24
# date_mday 20
# date_minute 60
r date_month 1
# date_second 60
r date_wday 7
# date_year 1
r date_zone 1
r domain 1
r index 1
# linecount 1
r method 2
r path 23
r punct 89
r referer 1
# size_bytes 100+
r splunk_server 1
# status 7
r time 100+
# timeendpos 2
# timestartpos 2
r user_agent 11

```

This is where the username can be found

11:52:57:198 PM host = lab source = access.csv sourcetype = web_traffic

> 10/20/25
2025-10-20T23:49:36.192.168.182.61,GET,/static/app.css,404,4072,https://tbfc.thm/, "Mozilla/5.0 (Macintosh; Intel Mac OS X 11_0_2) AppleWebKit/537.36, tbfc.thm

path

23 Values, 91.613% of events

Selected Yes No

Reports

Top values Top values by time Rare values

Events with this field

Top 10 Values	Count	%
/index.html	1,581	9.207%
/blog	1,567	9.125%
/	1,565	9.114%
/static/app.css	1,532	8.922%
/shop	1,526	8.886%
/contact	1,525	8.881%
/search?q=test	666	3.878%
/item.php?id=1	661	3.849%
/item.php?id=1 AND SLEEP(5)--	660	3.843%
/download?file=../../etc/passwd	658	3.832%

Time-based sql injection payload

The attack deliberately injected a command that delays the website to load for 5 seconds. It might not harmful that the attacker delays the website for 5 seconds when the user is doing something (ex. Redirect somewhere in the website), it proves the test of the attacker that the website is indeed vulnerable and can be injected malicious commands.

It confirms that something sketchy is going on since no user should be allowed in the path ../../etc/passwd where the username and other information of the users can be found.

```

1 index=main client_ip="198.51.100.55"
2 | stats count by time,user_agent,path,status

```

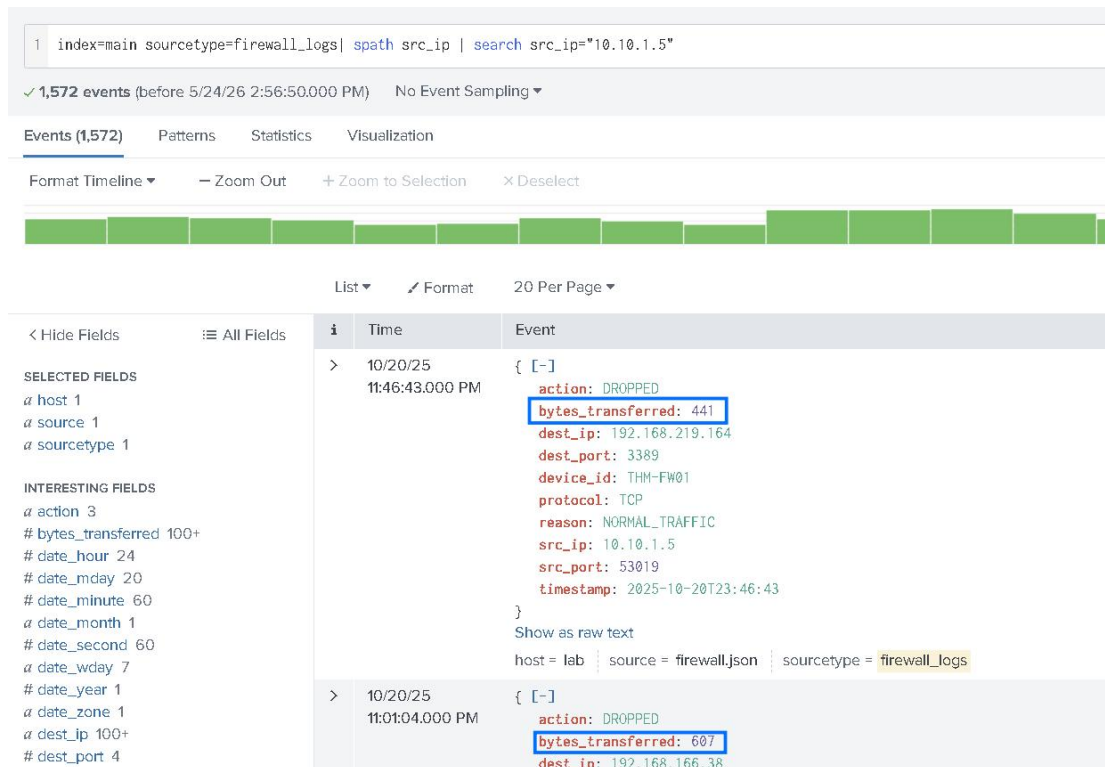
✓ 7,876 events (before 5/24/26 1:51:33.000 PM)
No Event Sampling

Events (7,876)
Patterns
Statistics (7,876)
Visualization

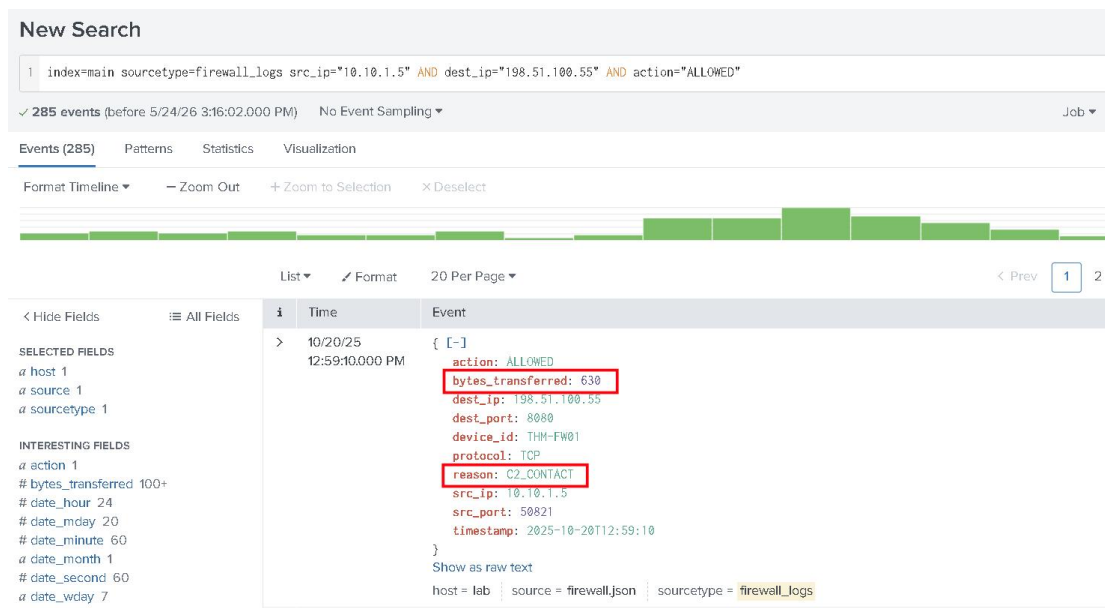
100 Per Page
Format
Preview

time	user_agent	path	status
2025-10-01T00:01:44	curl/7.88.1	/.env	401
2025-10-01T00:11:42	zgrab/0.x	/logs.tar.gz	403
2025-10-01T00:14:15	Wget/1.21.4	/search?q=test	200
2025-10-01T00:18:58	curl/7.88.1	/phpinfo.php	403
2025-10-01T00:25:39	zgrab/0.x	/server-status	403
2025-10-01T00:37:13	zgrab/0.x	/config.json	200
2025-10-01T00:58:51	zgrab/0.x	/?redirect=http://evil.site	403
2025-10-01T00:59:48	Go-http-client/1.1	/download?file=../../etc/passwd	200
2025-10-01T00:59:51	Go-http-client/1.1	/?redirect=http://evil.site	200
2025-10-01T01:01:23	Go-http-client/1.1	/.env	401
2025-10-01T01:05:56	Ruby/2.7.0 (WebsHELL Runner)	/shell.php?cmd=../../etc/passwd	200
2025-10-01T01:12:17	sqlmap/1.7.9#stable (http://sqlmap.org)	/item.php?id=1	500

This confirms that the attacker is using automated tools for attack but is forbidden (403), Unauthorized (401). Some of the attacks are succesful since the status is 200 (OK). But the most concerning part is the RED HIGHLIGHTED one. The attacker already uploaded a “shell.php” and run a binary file named “bunnylock.bin”, the attacker can now install a malware. We can assume that the server is already in the hands of attacker.



A very normal amount of bytes transferred from different IP



Now this is the attackers log. The reason is C2 contact (malicious activity). And the attacker gets a 630 bytes of data from just 1 transfer

New Search		Save As	Create Table View	Close
1 index=main sourcetype=firewall_logs src_ip="10.10.1.5" dest_ip="198.51.100.55" 2 stats sum(bytes_transferred) by src_ip		All time	Q	
✓ 285 events (before 5/24/26 3:39:19:000 PM) No Event Sampling		Job	II	Verbose Mode
Events (285) Patterns Statistics (1) Visualization				
100 Per Page Format Preview				
src_ip		sum(bytes_transferred)		
10.10.1.5		126167		

This is the total amount of bytes of data the attacker gets from all of the transfer. 126167 bytes of data, about 0.12 MB. Might be small, but it could contain or hold thousand lines of password or other credentials which is alarming.

Conclusion:

This Splunk investigation allowed me to practice analyzing logs and identifying suspicious activities within a web environment. By examining user agents, IP addresses, HTTP status codes, and data transfers, I was able to uncover multiple indicators of potential compromise.

The findings revealed evidence of command injection attempts, directory traversal attacks, unauthorized access attempts, and the possible deployment of a web shell. Further analysis also showed signs of command-and-control (C2) communication and data exfiltration, highlighting how attackers can move from reconnaissance to system compromise.

Overall, this exercise strengthened my skills in log analysis, threat detection, and incident investigation using Splunk. It emphasized the importance of continuous monitoring and early detection in protecting systems from cyber threats.